

Analyse de conformité ISO/IEC 27001:2022 de l'architecture SIEM basée sur Azure Monitor et Microsoft Sentinel

Wala Hassine - Smartovate LTD

June 4, 2026

1 Présentation de la norme ISO 27001

. L'ISO/IEC 27001:2022 est la norme internationale de référence pour les **Systèmes de Management de la Sécurité de l'Information (SMSI)**. Dans sa **troisième édition** publiée en **octobre 2022**, elle définit un **cadre structuré** permettant aux organisations d'établir, mettre en œuvre, maintenir et améliorer leur **posture de sécurité** de manière continue.

. La norme s'articule autour de **dix clauses principales**. Les **clauses 4 à 10** constituent le **corps normatif obligatoire** : **contexte de l'organisation, leadership, planification, support, fonctionnement, évaluation des performances et amélioration**. Ces clauses imposent une **approche de gestion basée sur le risque** — l'organisation identifie ses **actifs informationnels**, évalue les **menaces** et **vulnérabilités** associées, puis sélectionne des **contrôles adaptés** pour réduire les **risques** à un **niveau acceptable**.

. L'**Annexe A**, normative, liste **93 contrôles** regroupés en **quatre domaines** : **contrôles organisationnels** (5.x, 37 contrôles), **contrôles liés aux personnes** (6.x, 8 contrôles), **contrôles physiques** (7.x, 14 contrôles) et **contrôles technologiques** (8.x, 34 contrôles). Par rapport à la **version 2013**, l'**édition 2022** introduit notamment le **contrôle 5.23** dédié à la **sécurité des services en cloud** — une évolution directement pertinente pour tout **projet cloud**.

. La logique centrale de la norme repose sur la **triade CIA** : **Confidentialité, Intégrité** et **Disponibilité**. Tout contrôle sélectionné doit contribuer à préserver au moins l'un de ces trois attributs. Le **SMSI** ne se réduit pas à un ensemble d'**outils techniques** ; il couvre également les **processus**, les **personnes** et la **documentation**. C'est dans cette perspective globale que s'inscrit l'analyse du **projet SIEM**.

2 Contrôles ISO pertinents pour le projet SIEM Cloud-Native avec Azure Monitor & Sentinel

Le projet SIEM de SMARTOVATE LTD vise à déployer une infrastructure de supervision de sécurité centralisée sur Azure, intégrant Azure Monitor, Log Analytics, Azure Sentinel, et des Playbooks SOAR via Logic Apps. L'analyse ci-dessous identifie les contrôles ISO 27001:2022 directement adressés par ce projet.

Contrôle 8.15 — Enregistrement (Logging)

- C'est le contrôle le plus directement couvert. La norme exige que les journaux enregistrant activités, exceptions, défaillances et événements pertinents soient produits, stockés, protégés et analysés. Le projet répond à cette exigence par la création d'un espace de travail Log Analytics centralisé, avec une rétention configurée à 30 jours, et l'ingestion de journaux provenant d'Azure AD, Azure Activity, Office 365 et des machines virtuelles. L'alignement est fort et documenté.

Contrôle 8.16 — Activités de suivi (Monitoring)

- La norme requiert la surveillance des réseaux, systèmes et applications pour détecter tout comportement anormal. Azure Sentinel constitue le moteur central de détection : les règles d'analyse KQL personnalisées (5 à 10 règles prévues) identifient les connexions suspectes depuis des IP malveillantes, les connexions depuis des pays inhabituels, et les élévations de privilèges sur Azure AD. Les Workbooks fournissent une visualisation continue de la posture de sécurité. Cet alignement est direct et exhaustif.

Contrôle 5.25 — Évaluation des événements de sécurité et 5.26 — Réponse aux incidents

- La norme impose d'évaluer les événements de sécurité et d'y répondre selon des procédures documentées. Le projet implémente exactement ce processus : Azure Sentinel génère des incidents à partir des alertes déclenchées, les Playbooks SOAR automatisent la réponse (notification Teams, désactivation de compte Azure AD). La traçabilité est assurée par les commentaires ajoutés automatiquement aux incidents Sentinel. L'alignement est complet sur le plan technique ; la documentation des procédures reste à formaliser.

Contrôle 5.24 — Planification et préparation de la gestion des incidents

- La norme exige la définition préalable des processus, rôles et responsabilités pour la gestion des incidents. Le projet définit des critères d'acceptation clairs pour chaque User Story, notamment les sévérités d'incidents (Haute, Moyenne), les règles d'automatisation qui lient les Playbooks aux niveaux de sévérité, et les canaux de notification. La mise en place d'une Automation Rule constitue une implémentation technique de ce contrôle.

Contrôle 5.7 — Renseignements sur les menaces (Threat Intelligence)

- La norme demande la collecte et l'analyse d'informations sur les menaces afin de produire des renseignements exploitables. Le projet intègre la Threat Intelligence dans ses requêtes KQL pour la détection de connexions depuis des IP malveillantes connues. Cette capacité est explicitement mentionnée dans les critères d'acceptation de la User Story 2.1.

Contrôle 5.15 & 5.16 — Contrôle d'accès et gestion de l'identité

- La norme impose la gestion complète du cycle de vie des identités et l'application de règles de contrôle d'accès. Le projet surveille en temps réel les modifications de rôles sensibles dans Azure AD (ajout au rôle Administrateur Global) et automatise la révocation de sessions et la désactivation de comptes compromis. Les permissions RBAC de l'espace de travail Log Analytics sont définies pour restreindre l'accès à l'équipe de sécurité. L'alignement est fort sur la réponse aux incidents d'identité.

Contrôle 8.2 — Droits d'accès privilégiés

- La norme exige de restreindre et gérer l'attribution des droits d'accès privilégiés. Le projet intègre une règle de détection dédiée à l'élévation de privilèges (US 2.2), qui surveille les logs d'audit Azure AD et génère un incident de sévérité Haute lors de l'ajout à des rôles d'administrateur. C'est un alignement direct et proactif.

Contrôle 5.23 — Sécurité de l'information pour l'utilisation de services en nuage

- Ce contrôle, introduit dans l'édition 2022, demande d'établir des processus pour l'acquisition, l'utilisation, la gestion et la sortie des services cloud. Le projet opère entièrement sur Azure et utilise des services natifs Microsoft (Sentinel, Log Analytics, Logic Apps, Entra ID). La gouvernance des services cloud est donc inhérente à l'architecture. Toutefois, la norme attend une documentation formelle des politiques d'utilisation cloud — un livrable qui devra être produit en complément du guide technique.

Contrôle 9.1 — Suivi, mesure, analyse et évaluation

- La norme impose de définir ce qui doit être surveillé, avec des méthodes produisant des résultats reproductibles. Les Workbooks du projet (Vue d'ensemble sécurité, Analyse des identités) fournissent des métriques visualisables et filtrables (24h, 7 jours). Les règles KQL planifiées (exécution horaire) assurent la reproductibilité des mesures. L'alignement est satisfaisant.

Contrôle 5.28 — Collecte des preuves

- La norme requiert des procédures pour l'identification, la collecte et la conservation des preuves relatives aux événements de sécurité. Log Analytics stocke les événements bruts. Les Playbooks ajoutent des commentaires structurés dans les incidents Sentinel, constituant une traçabilité des actions de remédiation. La durée de rétention de 30 jours (environnement de test) devra être alignée sur les exigences légales en production.

Contrôle 8.6 — Gestion des capacités

- Azure Monitor collecte en continu les métriques de performance (CPU, mémoire, latence réseau) des ressources Azure. Cette supervision permet d'anticiper les saturations et d'ajuster les capacités selon les besoins. Le contrôle 8.6 est ainsi couvert en complément du rôle de collecte de logs qu'Azure Monitor partage avec le contrôle 8.15.

3 Cartographie ISO 27001 - Architecture

La cartographie ci-dessous représente la correspondance entre les composants techniques du projet et les contrôles ISO 27001:2022.

Composant Azure	Contrôle ISO	Description de l'alignement
Log Analytics Workspace	8.15 — Enregistrement	Centralise la collecte, le stockage et la protection des journaux provenant d' Azure AD , Azure Activity , Office 365 et VMs . Rétention configurable alignée sur les exigences de conservation.
Sentinel — Règles KQL	8.16 — Surveillance	Les Analytics Rules détectent les comportements anormaux (connexions suspectes, IP malveillantes).
	5.7 — Threat Intelligence	L'intégration de la Threat Intelligence étend la détection au-delà des anomalies comportementales. Les Watchlists filtrent les faux positifs .
Sentinel — Gestion des incidents	5.24 — Planification incidents	Structure les incidents Sentinel selon un processus préparé de classification et de traitement.
	5.25 — Évaluation événements	Corrèle les alertes en incidents avec mapping d'entités (Account , IP) et sévérité assignée (Haute, Moyenne).
	5.26 — Réponse incidents	Fournit l'implémentation technique du processus de réponse aux événements de sécurité .

Table 1: Cartographie des composants SIEM et contrôles ISO 27001:2022

Composant Azure	Contrôle ISO	Description de l'alignement
Logic Apps — Playbooks SOAR	5.26 — Réponse incidents	Playbook 1 : notification automatique sur Teams pour réduire le MTTD et accélérer la prise en charge.
	5.16 — Gestion des identités	Playbook 2 : désactivation du compte compromis via Microsoft Graph , avec traçabilité dans l' incident Sentinel .
Workbooks	9.1 — Suivi et mesure	Tableaux de bord interactifs : carte géographique, statistiques d' authentification et filtres temporels.
	5.35 — Revue indépendante	Support des revues périodiques de la posture de sécurité communicables à la direction.
RBAC sur Log Analytics	5.15 — Contrôle d'accès	Restreint l'accès au workspace Log Analytics à l' équipe SOC autorisée.
	5.18 — Droits d'accès	Applique le principe de moindre privilège sur les données de journalisation dès la création du workspace.
Règle détection privilèges	8.2 — Accès privilégiés	Surveille les logs d'audit Azure AD pour tout ajout à un rôle Administrateur Global .
	5.16 — Gestion des identités	Génère un incident de sévérité Haute avec mapping Account/IP pour l'identité concernée.
Architecture cloud native	5.23 — Services en nuage	Utilisation exclusive de services natifs Azure (Sentinel, Log Analytics, Logic Apps, Entra ID). Gouvernance cloud inhérente à l'architecture. Politique d'utilisation cloud formelle à documenter.
Environnement sandbox	8.31 — Séparation des environnements	Le projet opère dans un environnement de test isolé de la production . La séparation est effective mais non formellement documentée dans les livrables prévus.
Azure Monitor	8.15 — Enregistrement	Collecte et agrège les métriques et logs de l'ensemble de l' infrastructure Azure (VMs, pare-feux, services).
	8.16 — Surveillance	Constitue la couche d'observabilité primaire avant transmission à Log Analytics .
	8.6 — Gestion des capacités	Suit les métriques de performance et la disponibilité des ressources surveillées .

Table 2: Cartographie des composants SIEM et contrôles ISO 27001:2022 (suite)